🔒 Cybersécurité

NIS2 en France : entreprises concernées et plan d'action avant la loi Résilience

✍️ Goradieme • Publié le 23 octobre 2026 • ⏱ 12 min de lecture



Le 6 octobre 2026, l'Assemblée nationale a retiré de son ordre du jour, pour la deuxième fois, le projet de loi qui doit transposer NIS2 en France. Deux ans après l'échéance européenne, des milliers d'entreprises ne savent toujours pas précisément quand leurs obligations commenceront. Elles savent en revanche, ou peuvent savoir dès aujourd'hui, si elles sont concernées.

Ce guide répond aux deux questions que se posent cette semaine les dirigeants et les responsables sécurité : **quelles entreprises sont concernées par NIS2**, et que faire de manière utile pendant que la loi Résilience reste bloquée au Parlement. Il s'appuie sur le texte de la commission spéciale de l'Assemblée et sur les publications de l'ANSSI ; ce qui relève encore du projet est signalé comme tel.

POINTS CLÉS

- **La loi n'est pas votée, mais le périmètre est connu :** le texte en discussion vise les entreprises d'au moins 50 salariés, ou de plus de 10 millions d'euros de chiffre d'affaires et de

bilan, dans 18 secteurs.

- **Le retard français a désormais un coût politique :** la Commission européenne a décidé en juillet 2026 de saisir la Cour de justice contre la France.
- **L'ANSSI a déjà publié la grille de lecture :** le référentiel ReCyF, disponible depuis mars 2026, décrit les mesures attendues et peut être invoqué lors d'un contrôle.
- **Les fournisseurs sont concernés par ricochet :** un éditeur SaaS ou un prestataire hors périmètre devra prouver sa sécurité à des clients qui, eux, y sont soumis.

📋 **Sommaire**

1. **Où en est NIS2 en France en octobre 2026**
2. **NIS2 : quelles entreprises sont concernées**
3. **Ce que la loi exigera des entités régulées**
4. **Pourquoi attendre le vote est un mauvais calcul**
5. **Fournisseurs et éditeurs : l'effet chaîne d'approvisionnement**
6. **Le plan d'action en six étapes**
7. **Documenter pour prouver : le chantier oublié**
8. **Questions fréquentes**
9. **Sources**

1. Où en est NIS2 en France en octobre 2026

NIS2 n'est toujours pas transposée en France : aucune loi n'est promulguée et aucun décret d'application n'existe. Le projet de loi relatif à la résilience des infrastructures critiques et au renforcement de la cybersécurité, qui transpose aussi les directives REC et DORA, a été adopté par le Sénat le 12 mars 2025, puis par une commission spéciale de l'Assemblée nationale le 10 septembre 2025.

Son examen en séance publique était prévu les 7 et 9 octobre 2026. La veille, la conférence des présidents l'a retiré de l'ordre du jour, comme l'a rapporté **Next** (https://next.ink/brief-article/alleluia-la-transposition-de-nis2-est-enfin-a-lordre-du-jour-de-lassemblee-nationale/) : la raison avancée est un calendrier parlementaire chargé. Le rapporteur, Éric Bothorel, s'est dit optimiste : « J'ai bon espoir qu'on pourra réinscrire le texte d'ici quinze jours ou trois semaines ». À la mi-octobre, aucune nouvelle date n'avait été annoncée.

Un retard qui remonte à 2024

La directive (UE) 2022/2555 devait être transposée au plus tard le 17 octobre 2024. La Commission européenne a adressé une lettre de mise en demeure à la France le 28 novembre 2024, puis un avis motivé le 7 mai 2025. Le 8 juillet 2026, elle a annoncé **saisir la Cour de justice de l'Union européenne** (https://digital-strategy.ec.europa.eu/en/news/commission-refers-ireland-spain-france-and-netherlands-court-justice-failing-transpose-rules) contre l'Irlande, l'Espagne, la France et les Pays-Bas, en demandant une somme forfaitaire et des astreintes journalières jusqu'à la transposition complète.

Le texte reste par ailleurs disputé. Selon **Leto** (https://www.leto.legal/news/assemblee-nationale-report-projet-loi-resilience-nis2-octobre-2026), l'un des points de blocage est l'article 16 bis, introduit au Sénat, qui interdit d'imposer aux fournisseurs de chiffrement des dispositifs affaiblissant volontairement la sécurité. Pour une entreprise, la conséquence pratique est simple : la date d'entrée en vigueur est incertaine, mais le contenu des obligations, lui, est largement stabilisé.

2. NIS2 : quelles entreprises sont concernées

Sont concernées par NIS2 les entreprises qui exercent dans l'un des 18 secteurs listés par la directive et qui dépassent les seuils de la moyenne entreprise. L'ANSSI annonce, dans sa **plaquette de présentation** (https://monespacenis2.cyber.gouv.fr/statique/Plaquette_NIS2_2024.pdf), plus de 10 000 entités concernées dans 18 secteurs d'activité, parmi lesquelles des collectivités territoriales, des administrations, des moyennes et des grandes entreprises.

Deux catégories d'entités

Le texte adopté par la **commission spéciale de l'Assemblée nationale** (https://www.assemblee-nationale.fr/dyn/17/textes/l17b1779_texte-adopte-commission.pdf) (texte n° 1779) reprend la distinction européenne entre entités essentielles et entités importantes :

	ENTITÉ ESSENTIELLE	ENTITÉ IMPORTANTE
Secteurs	Secteurs hautement critiques (énergie, transports, banque, santé, eau, infrastructures numériques…)	Secteurs hautement critiques ou critiques (services postaux, gestion des déchets, industrie manufacturière, fournisseurs numériques…)
Seuils de taille	Au moins 250 salariés, ou plus de 50 M€ de chiffre d'affaires et plus de 43 M€ de bilan	Au moins 50 salariés, ou plus de 10 M€ de chiffre d'affaires et de bilan
Plafond d'amende	10 M€ ou 2 % du chiffre d'affaires annuel mondial	7 M€ ou 1,4 % du chiffre d'affaires annuel mondial

Deux précisions évitent des erreurs fréquentes. D'abord, la taille ne suffit pas : une entreprise de 400 salariés hors des secteurs listés n'est pas régulée à ce titre. Ensuite, certaines entités sont visées quelle que soit leur taille : le texte cite notamment les prestataires de services de confiance, les offices d'enregistrement de noms de domaine et les fournisseurs de services DNS. Le Premier ministre pourra aussi désigner une entité d'un secteur critique « quelle que soit sa taille ».

Le test à faire cette semaine

L'ANSSI met à disposition sur sa plateforme MonEspaceNIS2 un simulateur d'éligibilité, « Suis-je concerné ? », accessible depuis sa **page consacrée à la directive** (https://cyber.gouv.fr/reglementation/cybersecurite-systemes-dinformation/directives-nis-nis2-et-dispositif-saiv/directive-nis-2/). Le test prend quelques minutes et donne une première réponse argumentée, à confirmer avec votre conseil juridique dans les cas limites (groupes, filiales, activités multiples).

3. Ce que la loi exigera des entités régulées

Les entités concernées devront gérer leurs risques cyber de façon documentée, notifier leurs incidents importants dans des délais courts et engager la responsabilité de leur direction. Les délais ci-dessous sont ceux du texte de la commission spéciale ; ils peuvent encore évoluer en séance.

24 h
pour la notification initiale d'un incident important (texte n° 1779, septembre 2025)

72 h
pour la notification intermédiaire, puis un rapport final sous un mois

1 366
incidents traités par l'ANSSI en 2025 (Panorama de la cybermenace, mars 2026)

Une obligation de gouvernance

Le texte prévoit que les organes de direction approuvent et supervisent les mesures de sécurité, et que leurs membres soient formés à la cybersécurité en fonction de leur exposition au risque. La cybersécurité devient une question de comité de direction.

Des mesures de sécurité proportionnées

Les mesures portent sur la protection des réseaux et des systèmes d'information, « y compris en cas de recours à la sous-traitance », et doivent viser à réduire les dépendances envers des prestataires tiers qui ne présentent pas de garanties suffisantes. Le ReCyF de l'ANSSI applique un principe de proportionnalité : l'effort attendu est adapté à la maturité et aux ressources de chaque entité.

Une notification en trois temps

En cas d'incident important, l'entité devra prévenir l'autorité dans les 24 heures suivant sa connaissance de l'incident, compléter sa notification sous 72 heures, puis transmettre un rapport final au plus tard un mois après la notification intermédiaire. Ces délais supposent une procédure écrite et des rôles désignés à l'avance.

L'enjeu n'est pas théorique. Dans son **Panorama de la cybermenace 2025** (https://cyber.gouv.fr/actualites/panorama-de-la-cybermenace-2025/), publié le 11 mars 2026, l'ANSSI indique avoir traité 3 586 événements de sécurité, dont 1 366 incidents. Sur 460 événements caractérisés comme de possibles fuites de données, seuls 42 % ont pu être associés à une fuite avérée : savoir qualifier rapidement un incident fait partie de l'exigence.

4. Pourquoi attendre le vote est un mauvais calcul

Attendre la promulgation pour commencer revient à comprimer en quelques mois un travail qui en demande souvent plus d'un an. Deux raisons rendent l'attentisme coûteux, même sans sanction possible aujourd'hui.

Le référentiel attendu existe déjà

Depuis le 17 mars 2026, l'ANSSI met à disposition le Référentiel Cyber France (ReCyF), qui liste les mesures recommandées pour atteindre les objectifs de sécurité de NIS2. Il s'agit d'un document de travail, « par défaut non-obligatoire », mais l'ANSSI précise que les entités qui l'appliquent pourront s'en prévaloir lors d'un contrôle. Un outil permet de le comparer aux normes et référentiels que vous suivez peut-être déjà.

L'horizon de conformité se dessine

Auditionné le 1er octobre 2026 par la commission spéciale, le directeur général de l'ANSSI, Vincent Strubel, a évoqué une conformité complète de toutes les entités d'ici fin 2028, selon des propos rapportés par AEF info et repris par **Leto** (https://www.leto.legal/news/anssi-nis-2-conformite-complete-fin-2028-strubel-2026). Il s'agit d'une intention exprimée en audition, pas d'une règle écrite. Mais elle donne un ordre de grandeur : deux ans pour bâtir une gouvernance, déployer des mesures et en produire les preuves.

> **Le vrai risque à court terme n'est pas l'amende**
>
> Tant que la loi n'est pas promulguée, l'ANSSI ne peut pas sanctionner au titre de NIS2. Le risque immédiat est ailleurs : un incident sans procédure de crise, et des clients régulés qui exigeront des garanties de leurs fournisseurs.

5. Fournisseurs et éditeurs : l'effet chaîne d'approvisionnement

Une entreprise hors du périmètre de NIS2 peut quand même en subir les effets, parce que ses clients régulés devront maîtriser les risques liés à leurs prestataires. C'est le cas typique d'un éditeur SaaS de 30 personnes qui vend à des hôpitaux, des banques ou des industriels.

Concrètement, le texte français demande aux entités régulées de protéger leurs systèmes « y compris en cas de recours à la sous-traitance » et de réduire leurs dépendances envers les prestataires qui ne présentent pas de garanties suffisantes. Elles répercuteront donc des exigences sur leurs fournisseurs : questionnaires de sécurité plus détaillés, clauses contractuelles, demandes de preuves (politique de sécurité, plan de réponse aux incidents, gestion des accès, sauvegardes, localisation des données).

Ce que cela change pour un éditeur SaaS

- **Des cycles de vente plus longs** si les réponses de sécurité ne sont pas prêtes.
- **Un avantage concurrentiel** pour celui qui publie une documentation de sécurité claire, à jour et cohérente avec ses contrats.
- **Un risque de déréférencement** chez les grands comptes qui rationalisent leurs prestataires pour réduire leurs dépendances non maîtrisées.

Les accès techniques des prestataires méritent une attention particulière : comptes de service, clés d'API et jetons d'intégration sont souvent le maillon faible. Notre guide sur les identités non humaines détaille les risques documentés et les bonnes pratiques pour les sécuriser.

6. Le plan d'action en six étapes

Le bon ordre consiste à établir le périmètre, puis la gouvernance, puis les mesures, et enfin les preuves. Voici une séquence réaliste pour une entreprise de 50 à 500 salariés, à adapter à sa maturité.

1. **Qualifier votre statut (semaine 1).** Passer le test d'éligibilité de MonEspaceNIS2 pour chaque entité juridique du groupe, et consigner la conclusion et son raisonnement dans une note datée. Si vous êtes seulement fournisseur, listez vos clients probablement régulés.
2. **Désigner un responsable et informer la direction (mois 1).** Nommer un pilote, présenter les enjeux au comité de direction et planifier la formation des dirigeants que le texte prévoit.
3. **Se pré-enregistrer.** L'ANSSI a ouvert un service de pré-enregistrement, réservé pour l'instant aux entreprises, et encourage à s'inscrire tôt pour faciliter les démarches une fois les règles applicables.
4. **Mesurer l'écart au ReCyF (mois 2 et 3).** Comparer vos pratiques aux mesures du référentiel, en partant de l'existant si vous suivez déjà ISO 27001 ou un autre cadre. Classer les écarts par risque et par coût.
5. **Préparer la gestion d'incident (mois 3 et 4).** Rédiger la procédure de notification en trois temps, les modèles de messages, l'annuaire de crise, et la tester au moins une fois par un exercice.
6. **Traiter les fournisseurs et produire les preuves (mois 4 à 12).** Cartographier vos prestataires critiques, revoir les clauses, et constituer un dossier de conformité tenu à jour.

Pour les structures les moins mûres, l'ANSSI a annoncé un socle de mesures de base, plus accessible que le ReCyF, adossé à son programme Cyber Départ.

7. Documenter pour prouver : le chantier oublié

La conformité NIS2 se démontre par écrit : une mesure non documentée est, pour un contrôleur comme pour un acheteur, une mesure qui n'existe pas.

Les documents à produire

DOCUMENT	DESTINATAIRE PRINCIPAL	CE QU'IL DOIT DÉMONTRER
Politique de sécurité des systèmes d'information	Direction, ANSSI	Des objectifs approuvés et des responsabilités claires
Procédure de gestion et de notification d'incident	Équipes internes, ANSSI	La capacité à tenir les délais de 24 h, 72 h et un mois
Registre des prestataires critiques	Direction, auditeurs	La maîtrise des dépendances et des accès tiers
Dossier de sécurité commercial	Clients et prospects	Des réponses cohérentes aux questionnaires de sécurité
Supports de formation des dirigeants	Comité de direction	Une formation effective et traçable

Faire de la conformité un argument

Pour un éditeur ou un prestataire, une partie de ce travail peut servir la vente. Une page sécurité précise, un livre blanc qui explique votre approche de NIS2 sans promesse excessive, ou une documentation technique qui répond d'avance aux questions récurrentes des acheteurs raccourcissent les cycles de décision. La règle d'or reste l'exactitude : n'affirmez jamais une conformité que la loi ne permet pas encore de constater, et décrivez plutôt les mesures en place et le référentiel suivi.

TechRepair Content accompagne les acteurs de la cybersécurité sur ce type de contenus, et notre offre de livres blancs peut traiter des sujets réglementaires comme NIS2 ou DORA.

Questions fréquentes

NIS2 s'applique-t-elle déjà en France ?

Non. Au 23 octobre 2026, la loi de transposition n'est pas votée et aucune obligation NIS2 n'est opposable en droit français. Le projet a été retiré de l'ordre du jour de l'Assemblée nationale le 6 octobre 2026, et aucune nouvelle date n'avait été annoncée à la mi-octobre.

Comment savoir si mon entreprise est concernée par NIS2 ?

Il faut croiser votre secteur d'activité avec les 18 secteurs de la directive et vos effectifs, chiffre d'affaires et bilan avec les seuils (50 salariés, ou plus de 10 M€ de chiffre d'affaires et de bilan). Le simulateur « Suis-je concerné ? » de l'ANSSI sur MonEspaceNIS2 donne une première réponse.

Le référentiel ReCyF est-il obligatoire ?

Non. L'ANSSI le présente comme un document de travail, non obligatoire par défaut. Les entités qui l'appliquent pourront toutefois s'en prévaloir lors d'un contrôle, ce qui en fait la base de travail la plus sûre en attendant la loi.

Mon entreprise n'est pas concernée : NIS2 peut-elle quand même m'affecter ?

Oui, si vous fournissez des services à des entités régulées. Elles devront maîtriser les risques liés à leurs prestataires et pourront vous demander davantage de garanties de sécurité, dans les contrats comme dans les appels d'offres.

En résumé

Le calendrier de NIS2 reste suspendu au Parlement, mais son contenu est connu : un périmètre défini par secteur et par taille, une responsabilité de la direction, des notifications sous 24 et 72 heures et un référentiel déjà publié par l'ANSSI. Les entreprises qui qualifient leur statut, se pré-enregistrent et documentent leurs mesures dès maintenant aborderont le vote sereinement, et celles qui vendent à des entités régulées en feront un argument commercial.

Parler de vos contenus de conformité cyber →

Sources

1. Commission européenne, « Commission refers Ireland, Spain, France and the Netherlands to the Court of Justice for failing to transpose the rules on cybersecurity », 8 juillet 2026. digital-strategy.ec.europa.eu
2. Assemblée nationale, « Projet de loi relatif à la résilience des infrastructures critiques et au renforcement de la cybersécurité », texte de la commission spéciale n° 1779, septembre 2025. assemblee-nationale.fr
3. ANSSI, « La directive NIS 2 ». cyber.gouv.fr
4. ANSSI, « NIS 2 : l'ANSSI poursuit et renforce sa dynamique d'accompagnement », 18 mars 2026. cyber.gouv.fr
5. ANSSI, plaquette de présentation de la directive NIS 2, 2024. monespacenis2.cyber.gouv.fr
6. ANSSI, « Panorama de la cybermenace 2025 : La France toujours sous la pression des cyber attaquants », 11 mars 2026. cyber.gouv.fr
7. Gavois S., « Caramba, encore raté : la transposition de NIS2 est de nouveau repoussée », Next, 6 octobre 2026. next.ink
8. Leto, « Transposition NIS 2 : le projet de loi Résilience de nouveau reporté », 6 octobre 2026, et « NIS 2 : l'ANSSI envisage d'exiger une conformité complète des entités d'ici fin 2028 », 13 octobre 2026. leto.legal